

Laboratorio 9

Sesión #9 Prácticas de contraseña segura (creación y gestión)

Título del Laboratorio: Prácticas de contraseña segura (creación y gestión)

Duración: 2 hora

Objetivos del Laboratorio:

1. Establecer Políticas de Contraseñas Seguras en un Entorno de TI
2. Implementar Mecanismos de Bloqueo de Cuenta tras Intentos Fallidos
3. Verificar y Documentar la Configuración de Seguridad de Contraseñas:

Materiales Necesarios:

1. Utilizar GitHub como repositorio
2. Utilizar Academia Cisco
3. Computador
4. Acceso a internet

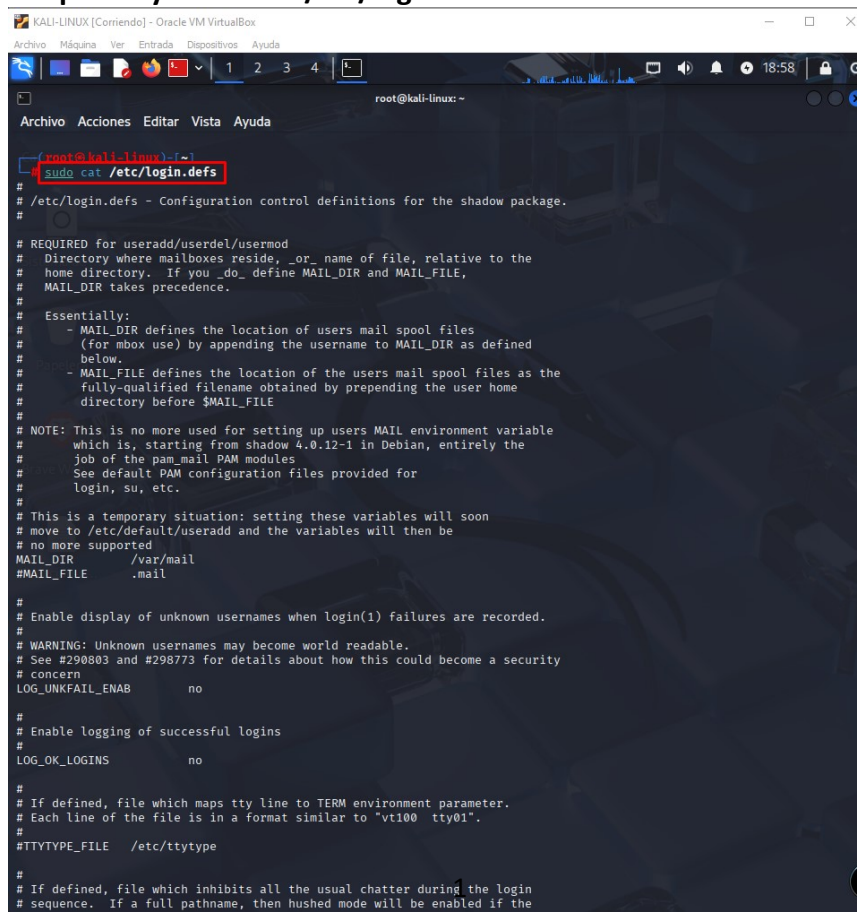
Estructura del Laboratorio:

Parte 1: Configuración de Políticas de Contraseñas Seguras

- Paso 1: Revisión de la Configuración Actual

R//

Verificamos la política de contraseñas actual en Linux se realiza revisando el archivo de configuración pam.d y el archivo /etc/login.defs:



```

root@kali-linux: ~
Archivo Acciones Editar Vista Ayuda

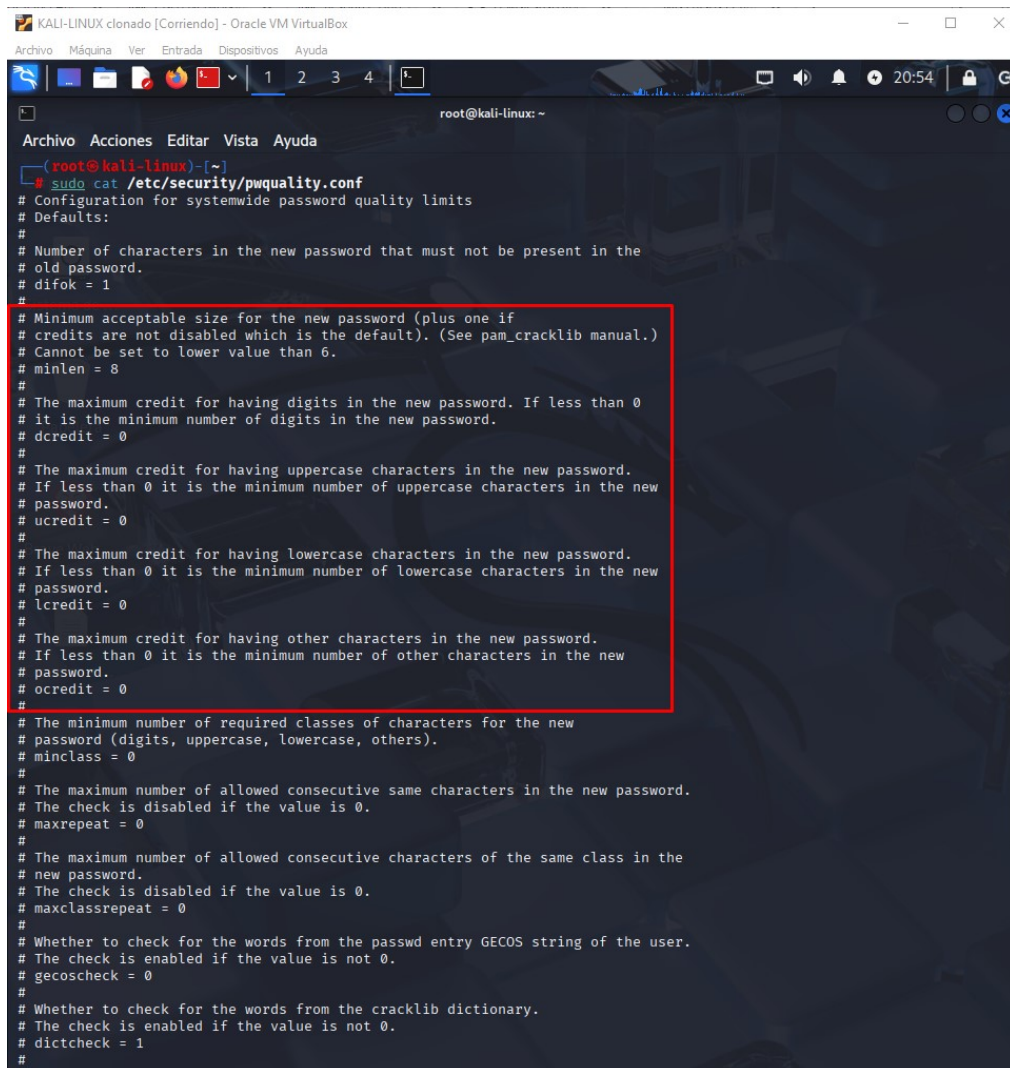
root@kali-linux:~# sudo cat /etc/login.defs
#
# /etc/login.defs - Configuration control definitions for the shadow package.
#
# REQUIRED for useradd/userdel/usermod
#   Directory where mailboxes reside, _or_ name of file, relative to the
#   home directory.  If you _do_ define MAIL_DIR and MAIL_FILE,
#   MAIL_DIR takes precedence.
#
# Essentially:
#   - MAIL_DIR defines the location of users mail spool files
#     (for mbox use) by appending the username to MAIL_DIR as defined
#     below.
#   - MAIL_FILE defines the location of the users mail spool files as the
#     fully-qualified filename obtained by prepending the user home
#     directory before $MAIL_FILE
#
# NOTE: This is no more used for setting up users MAIL environment variable
#       which is, starting from shadow 4.0.12-1 in Debian, entirely the
#       job of the pam_mail PAM modules
#       See default PAM configuration files provided for
#       login, su, etc.
#
# This is a temporary situation: setting these variables will soon
# move to /etc/default/useradd and the variables will then be
# no more supported
MAIL_DIR    /var/mail
MAIL_FILE   .mail
#
# Enable display of unknown usernames when login(1) failures are recorded.
#
# WARNING: Unknown usernames may become world readable.
# See #290803 and #298773 for details about how this could become a security
# concern
LOG_UNKFAIL_ENAB    no
#
# Enable logging of successful logins
#
LOG_OK_LOGINS       no
#
# If defined, file which maps tty line to TERM environment parameter.
# Each line of the file is in a format similar to "vt100  tty01".
#
#TTYTYPE_FILE       /etc/ttytype
#
# If defined, file which inhibits all the usual chatter during the login
# sequence.  If a full pathname, then hushed mode will be enabled if the
  
```

```
KALI-LINUX [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
root@kali-linux: ~
# Password aging controls:
#
# PASS_MAX_DAYS Maximum number of days a password may be used.
# PASS_MIN_DAYS Minimum number of days allowed between password changes.
# PASS_WARN_AGE Number of days warning given before a password expires.
#
PASS_MAX_DAYS 99999
PASS_MIN_DAYS 0
PASS_WARN_AGE 7
#
# Min/max values for automatic uid selection in useradd(8)
#
UID_MIN 1000
UID_MAX 60000
# System accounts
#SYS_UID_MIN 101
#SYS_UID_MAX 999
# Extra per user uids
SUB_UID_MIN 100000
SUB_UID_MAX 600100000
SUB_UID_COUNT 65536
#
# Min/max values for automatic gid selection in groupadd(8)
#
GID_MIN 1000
GID_MAX 60000
# System accounts
#SYS_GID_MIN 101
#SYS_GID_MAX 999
# Extra per user group ids
SUB_GID_MIN 100000
SUB_GID_MAX 600100000
SUB_GID_COUNT 65536
#
# Max number of login(1) retries if password is bad
# This will most likely be overridden by PAM, since the default pam_unix module
# has it's own built in of 3 retries. However, this is a safe fallback in case
# you are using an authentication module that does not enforce PAM_MAXTRIES.
#
LOGIN_RETRIES 5
#
# Max time in seconds for login(1)
#
LOGIN_TIMEOUT 60
#
# Which fields may be changed by regular users using chfn(1) - use
```

sudo cat /etc/pam.d/common-password

```
KALI-LINUX clonado [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
root@kali-linux: ~
Archivo Acciones Editar Vista Ayuda
(root@kali-linux)-[~]
# sudo cat /etc/pam.d/common-password
# /etc/pam.d/common-password - password-related modules common to all services
#
# This file is included from other service-specific PAM config files,
# and should contain a list of modules that define the services to be
# used to change user passwords. The default is pam_unix.
#
# Explanation of pam_unix options:
# The "yescrypt" option enables
#hashed passwords using the yescrypt algorithm, introduced in Debian
#11. Without this option, the default is Unix crypt. Prior releases
#used the option "sha512"; if a shadow password hash will be shared
#between Debian 11 and older releases replace "yescrypt" with "sha512"
#for compatibility. The "obscure" option replaces the old
# "OBSCURE_CHECKS_ENAB" option in login.defs. See the pam_unix manpage
#for other options.
#
# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules. See
# pam-auth-update(8) for details.
#
# here are the per-package modules (the "Primary" block)
password [success=2 default=ignore] pam_unix.so obscure yescrypt
password [success=1 default=ignore] pam_winbind.so try_authok try_first_pass
# here's the fallback if no module succeeds
password requisite pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
password required pam_permit.so
# and here are more per-package modules (the "Additional" block)
password optional pam_gnome_keyring.so
# end of pam-auth-update config
(root@kali-linux)-[~]
#
```

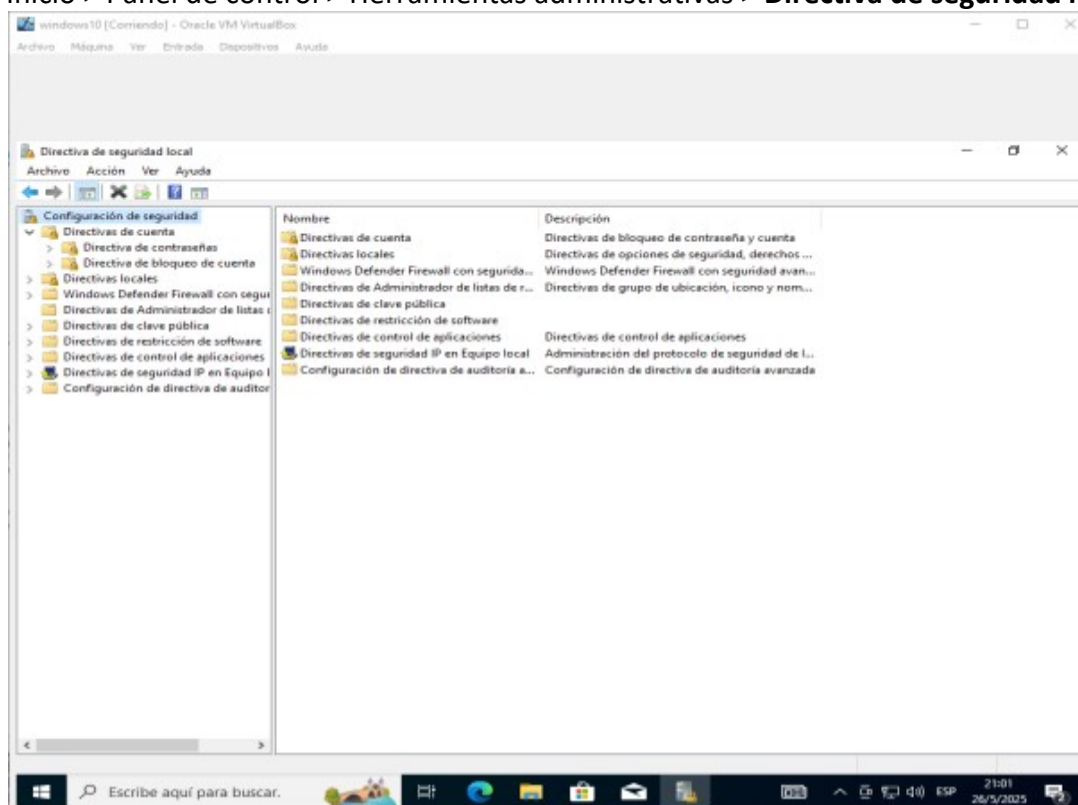
sudo cat /etc/security/pwquality.conf

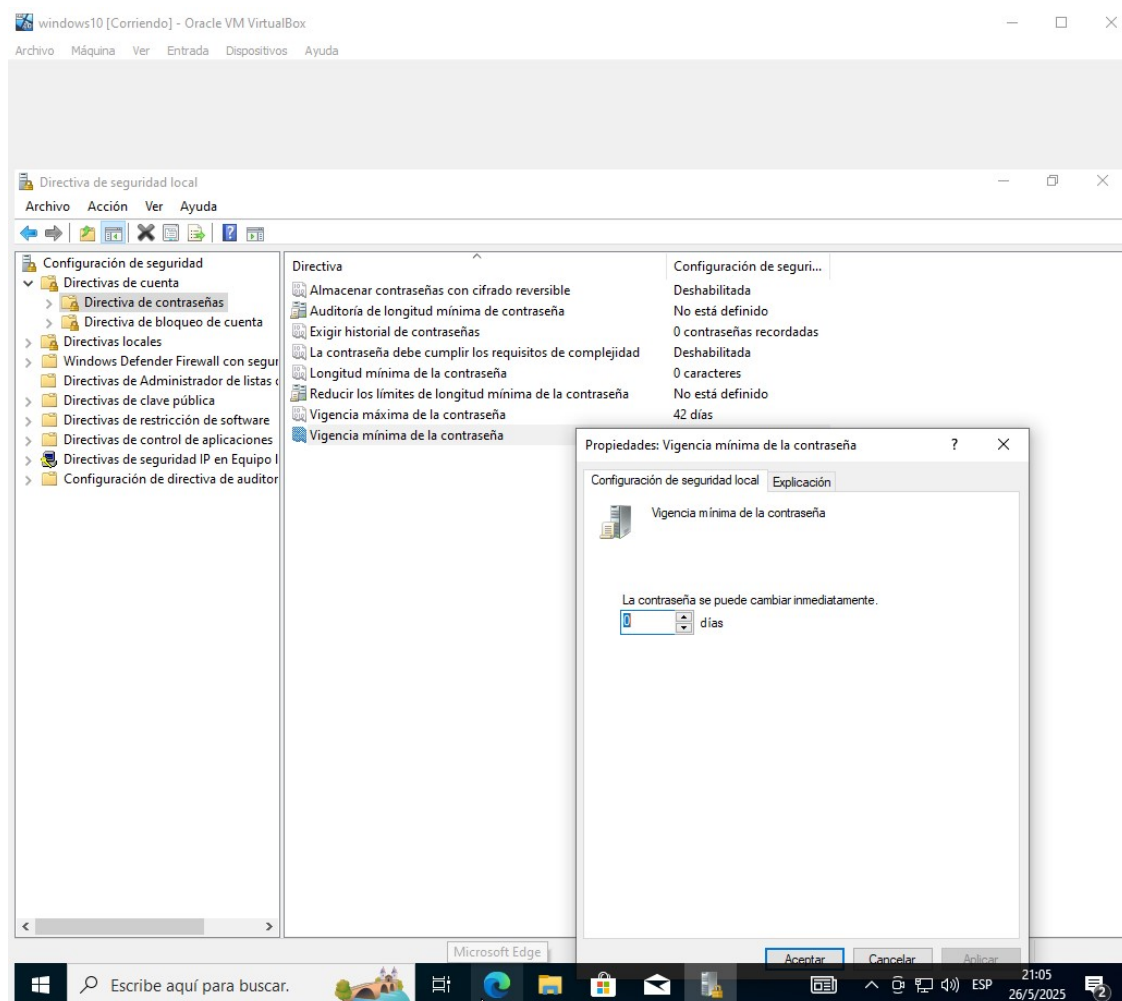
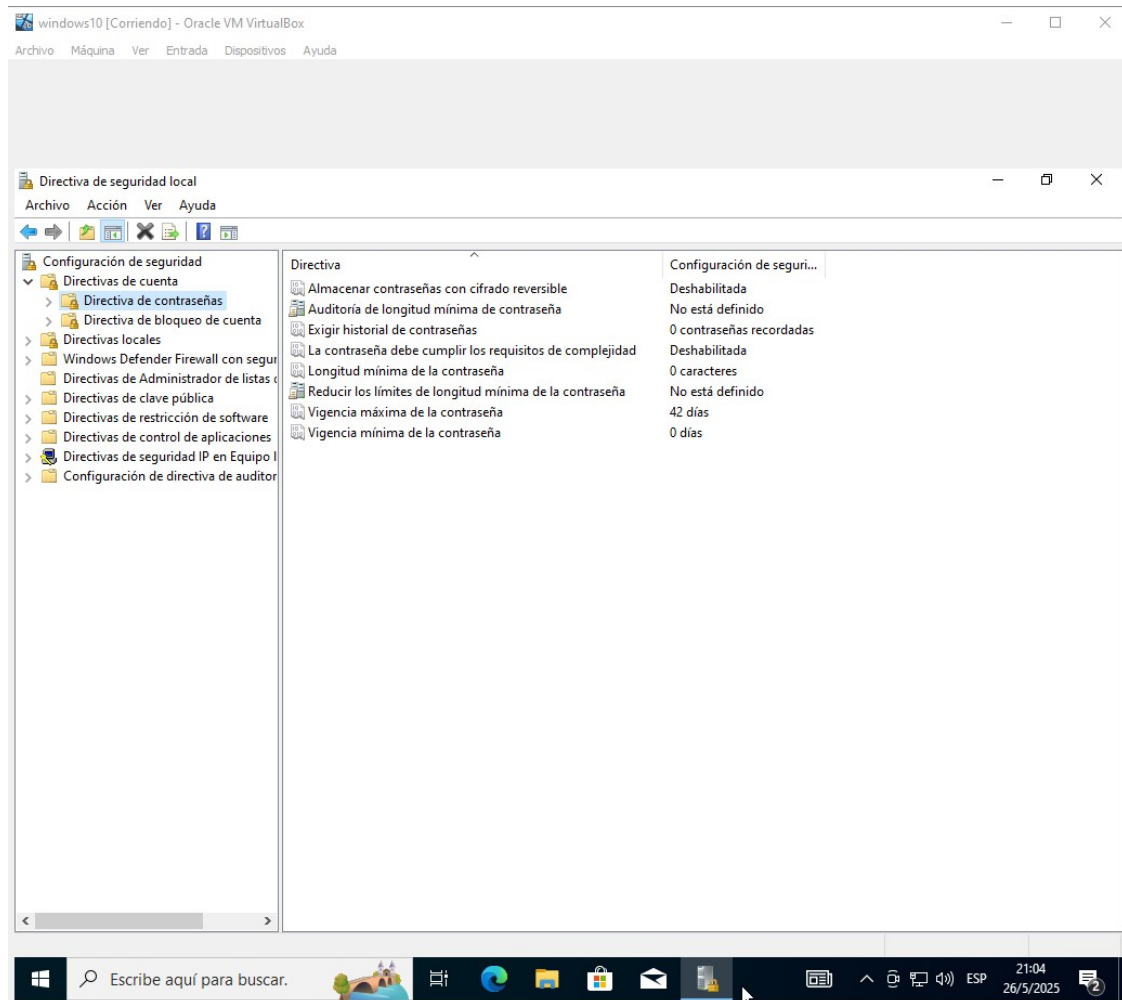


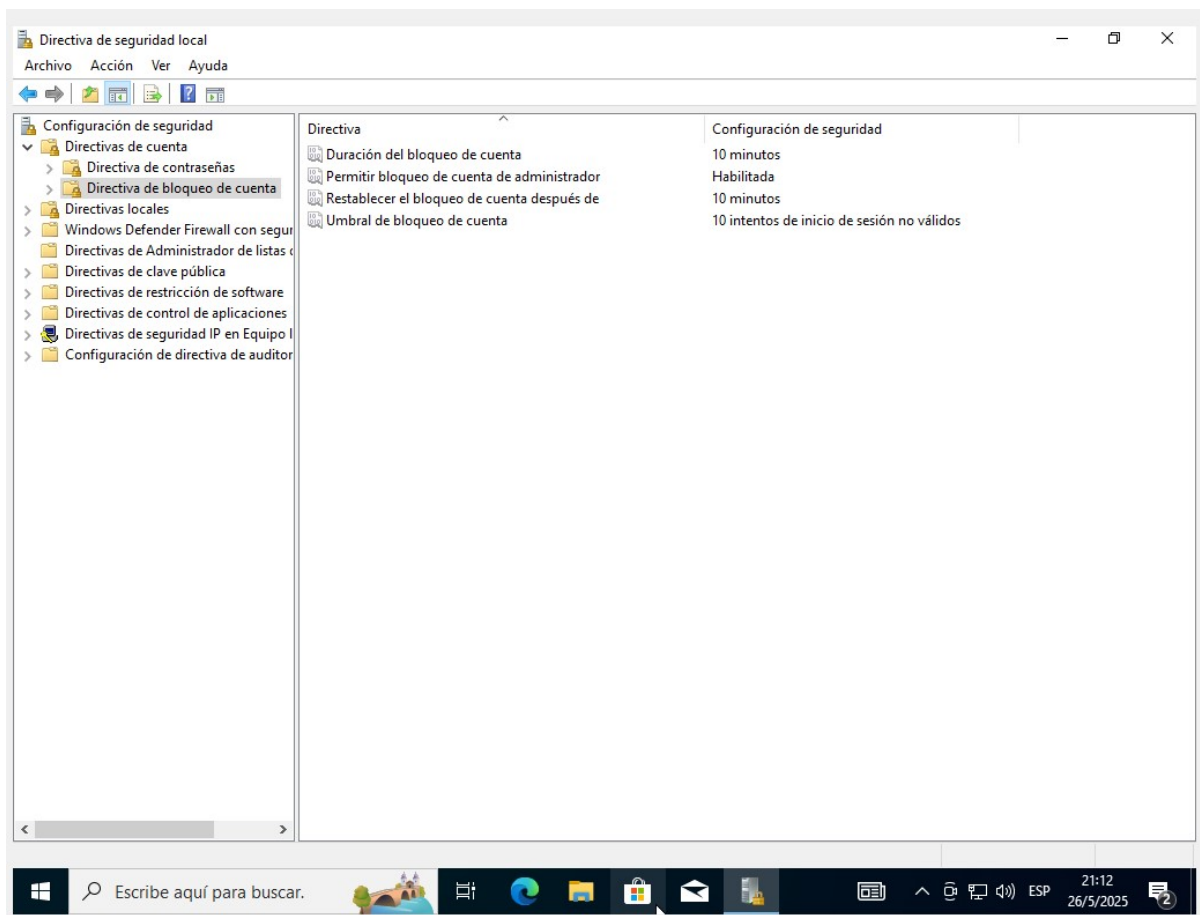
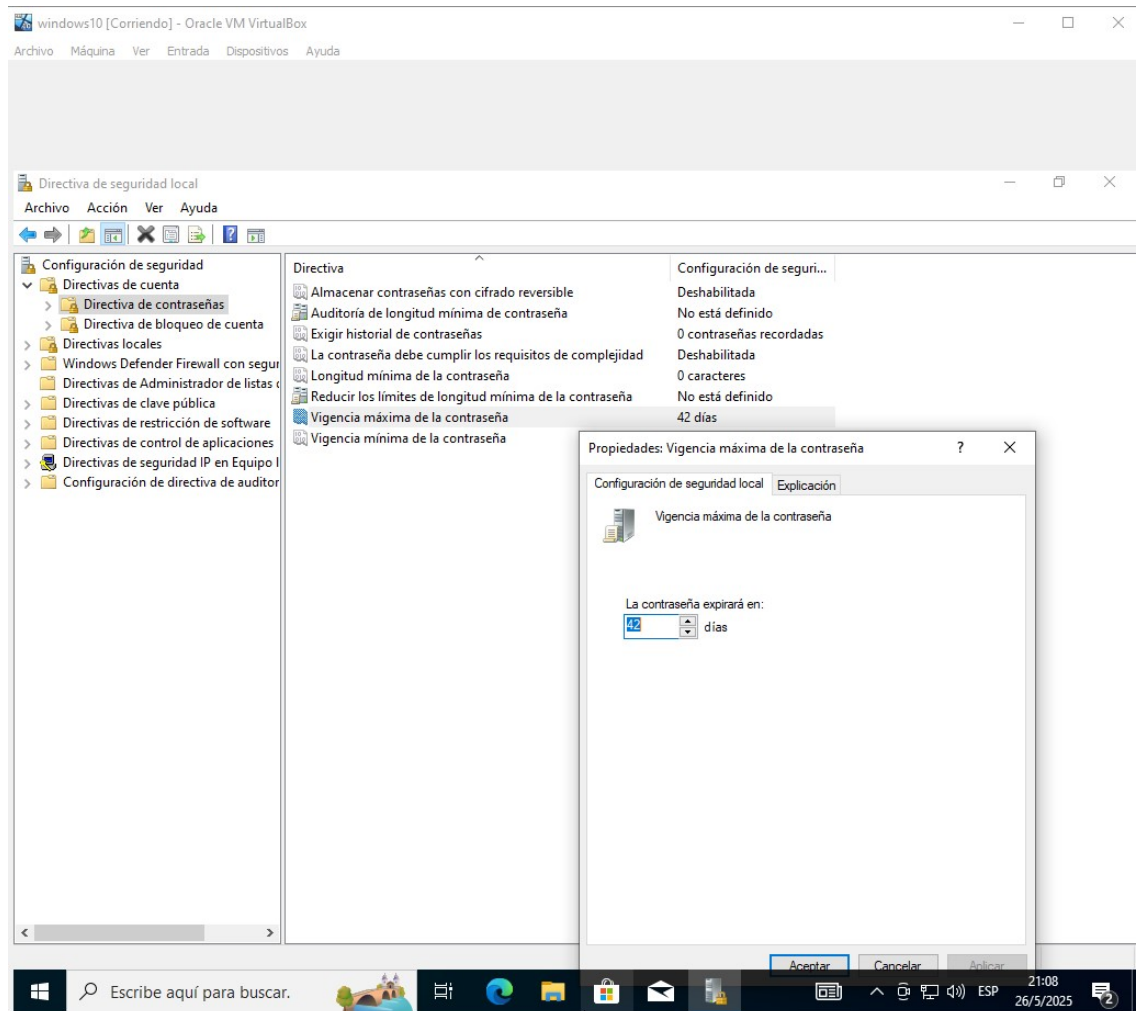
```
root@kali-linux: ~  
Archivo Acciones Editar Vista Ayuda  
(root@kali-linux)-[~]  
# sudo cat /etc/security/pwquality.conf  
# Configuration for systemwide password quality limits  
# Defaults:  
#  
# Number of characters in the new password that must not be present in the  
# old password.  
# difok = 1  
#  
# Minimum acceptable size for the new password (plus one if  
# credits are not disabled which is the default). (See pam_cracklib manual.)  
# Cannot be set to lower value than 6.  
# minlen = 8  
#  
# The maximum credit for having digits in the new password. If less than 0  
# it is the minimum number of digits in the new password.  
# dcredit = 0  
#  
# The maximum credit for having uppercase characters in the new password.  
# If less than 0 it is the minimum number of uppercase characters in the new  
# password.  
# ucredit = 0  
#  
# The maximum credit for having lowercase characters in the new password.  
# If less than 0 it is the minimum number of lowercase characters in the new  
# password.  
# lcredit = 0  
#  
# The maximum credit for having other characters in the new password.  
# If less than 0 it is the minimum number of other characters in the new  
# password.  
# ocredit = 0  
#  
# The minimum number of required classes of characters for the new  
# password (digits, uppercase, lowercase, others).  
# minclass = 0  
#  
# The maximum number of allowed consecutive same characters in the new password.  
# The check is disabled if the value is 0.  
# maxrepeat = 0  
#  
# The maximum number of allowed consecutive characters of the same class in the  
# new password.  
# The check is disabled if the value is 0.  
# maxclassrepeat = 0  
#  
# Whether to check for the words from the passwd entry GECOS string of the user.  
# The check is enabled if the value is not 0.  
# gecheck = 0  
#  
# Whether to check for the words from the cracklib dictionary.  
# The check is enabled if the value is not 0.  
# dictcheck = 1  
#
```

Windows:

Ve a Inicio > Panel de control > Herramientas administrativas > Directiva de seguridad local.



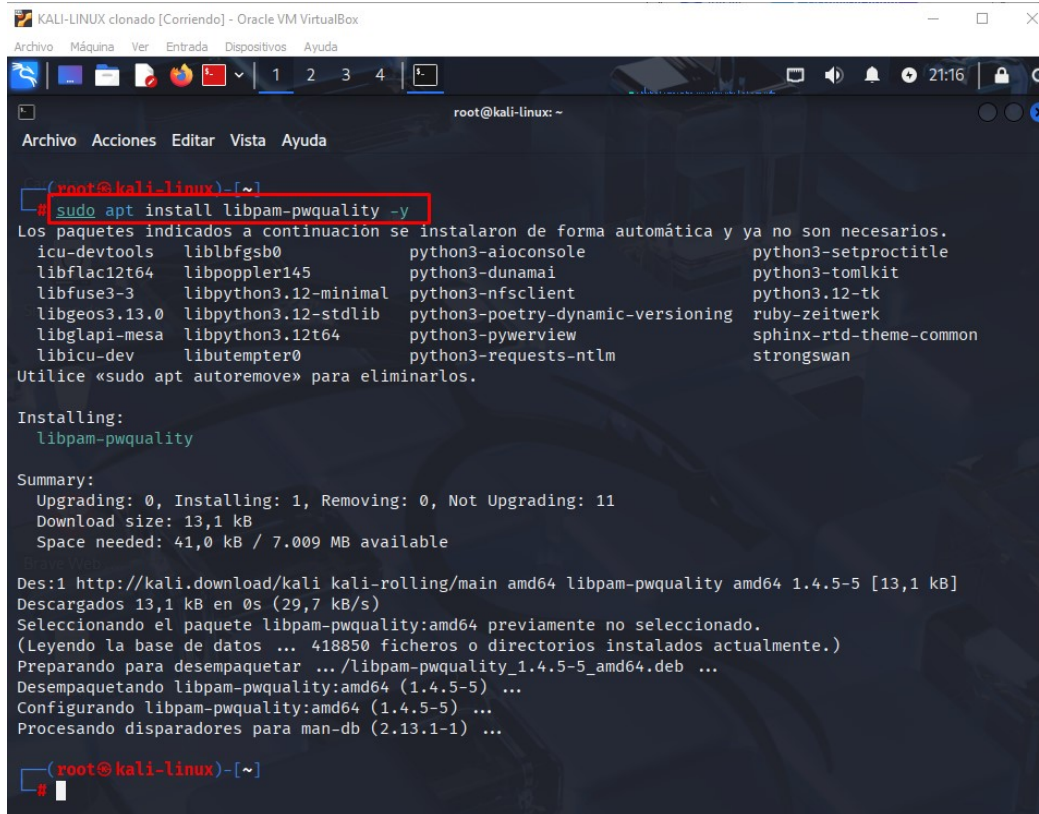




Paso 2: Configuración de la Longitud Mínima y Complejidad de las Contraseñas

R//

Procedemos a instalar el paquete libpam-pwquality (si no está instalado):



```
KALI-LINUX clonado [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
root@kali-linux: ~
Archivo Acciones Editar Vista Ayuda
root@kali-linux:~# sudo apt install libpam-pwquality -y
Los paquetes indicados a continuación se instalaron de forma automática y ya no son necesarios.
icu-devtools liblbfgsb0 python3-aioconsole python3-setproctitle
libflac12t64 libpoppler145 python3-dunamai python3-tomlkit
libfuse3-3 libpython3.12-minimal python3-nfsclient python3.12-tk
libgeos3.13.0 libpython3.12-stdlib python3-poetry-dynamic-versioning ruby-zeitwerk
libglapi-mesa libpython3.12t64 python3-pywerview sphinx-rtd-theme-common
libicu-dev libutempter0 python3-requests-ntlm strongswan
Utilice «sudo apt autoremove» para eliminarlos.

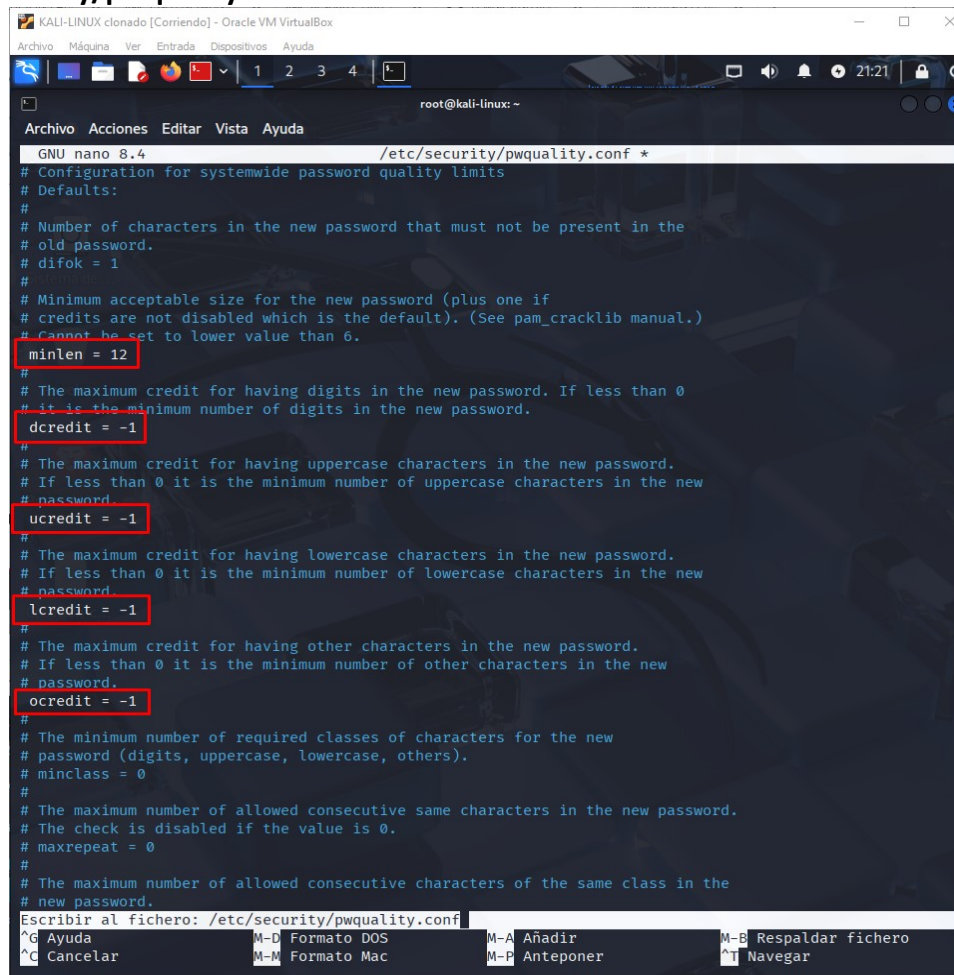
Installing:
libpam-pwquality

Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 11
Download size: 13,1 kB
Space needed: 41,0 kB / 7.009 MB available

Des:1 http://kali.download/kali kali-rolling/main amd64 libpam-pwquality amd64 1.4.5-5 [13,1 kB]
Descargados 13,1 kB en 0s (29,7 kB/s)
Seleccionando el paquete libpam-pwquality:amd64 previamente no seleccionado.
(Leyendo la base de datos ... 418850 ficheros o directorios instalados actualmente.)
Preparando para desempaquetar ... /libpam-pwquality_1.4.5-5_amd64.deb ...
Desempaquetando libpam-pwquality:amd64 (1.4.5-5) ...
Configurando libpam-pwquality:amd64 (1.4.5-5) ...
Procesando disparadores para man-db (2.13.1-1) ...

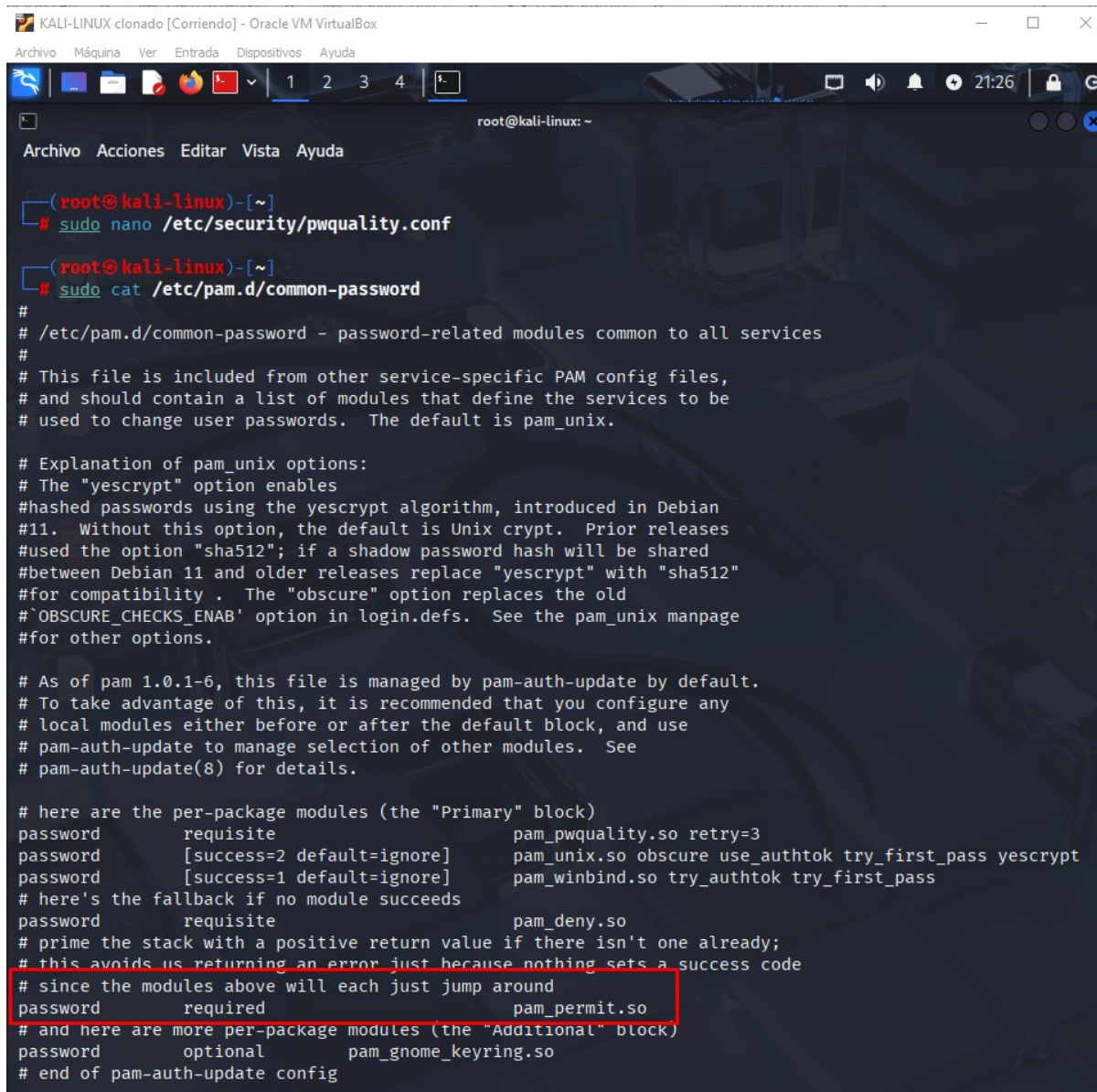
root@kali-linux:~#
```

Procedemos a configurar la longitud mínima y la complejidad de las contraseñas en el archivo `/etc/security/pwquality.conf`:



```
KALI-LINUX clonado [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
root@kali-linux: ~
Archivo Acciones Editar Vista Ayuda
GNU nano 8.4 /etc/security/pwquality.conf *
# Configuration for systemwide password quality limits
# Defaults:
#
# Number of characters in the new password that must not be present in the
# old password.
# difok = 1
#
# Minimum acceptable size for the new password (plus one if
# credits are not disabled which is the default). (See pam_cracklib manual.)
# Cannot be set to lower value than 6.
minlen = 12
#
# The maximum credit for having digits in the new password. If less than 0
# it is the minimum number of digits in the new password.
dcredit = -1
#
# The maximum credit for having uppercase characters in the new password.
# If less than 0 it is the minimum number of uppercase characters in the new
# password.
ucredit = -1
#
# The maximum credit for having lowercase characters in the new password.
# If less than 0 it is the minimum number of lowercase characters in the new
# password.
lcredit = -1
#
# The maximum credit for having other characters in the new password.
# If less than 0 it is the minimum number of other characters in the new
# password.
ocredit = -1
#
# The minimum number of required classes of characters for the new
# password (digits, uppercase, lowercase, others).
# minclass = 0
#
# The maximum number of allowed consecutive same characters in the new password.
# The check is disabled if the value is 0.
# maxrepeat = 0
#
# The maximum number of allowed consecutive characters of the same class in the
# new password.
Escribir al fichero: /etc/security/pwquality.conf
^G Ayuda M-D Formato DOS M-A Añadir M-B Respalidar fichero
^C Cancelar M-M Formato Mac M-P Anteponer M-T Navegar
```


Visualizamos el archivo `/etc/pam.d/common-password` para que use el módulo `pam_pwquality.so`:



```
(root@kali-linux)-[~]
# sudo nano /etc/security/pwquality.conf

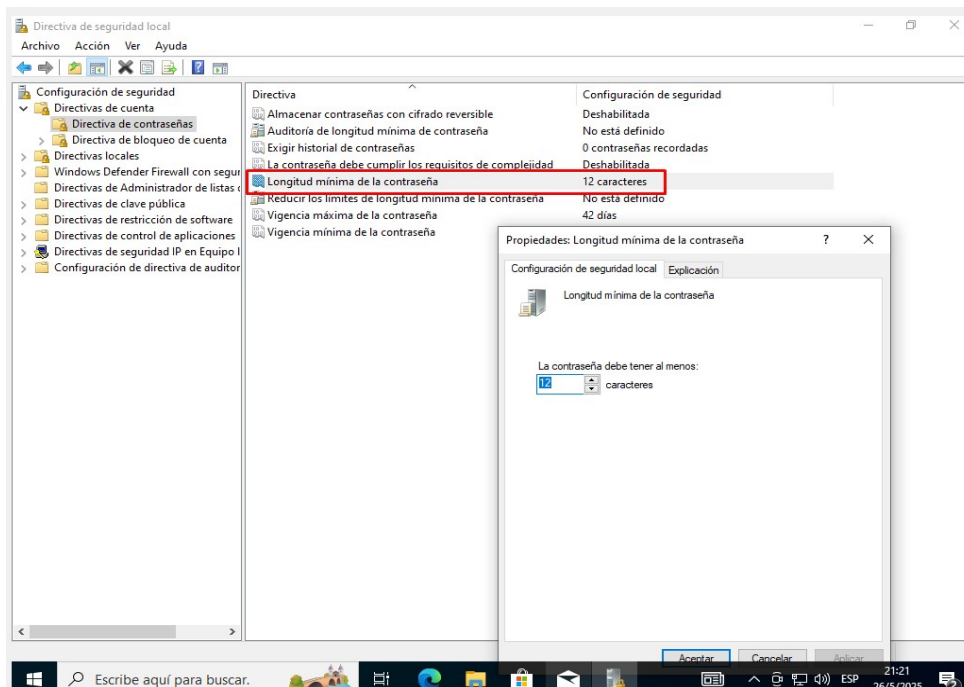
(root@kali-linux)-[~]
# sudo cat /etc/pam.d/common-password
#
# /etc/pam.d/common-password - password-related modules common to all services
#
# This file is included from other service-specific PAM config files,
# and should contain a list of modules that define the services to be
# used to change user passwords. The default is pam_unix.

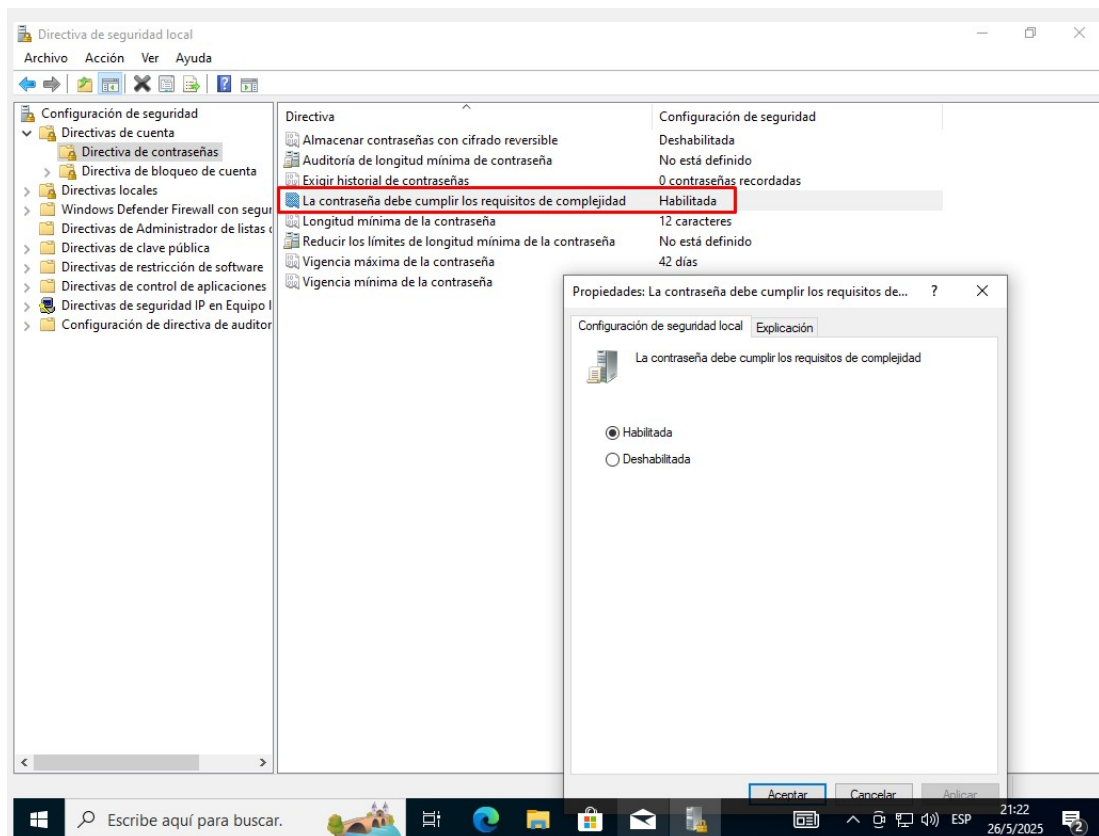
# Explanation of pam_unix options:
# The "yescrypt" option enables
# hashed passwords using the yescrypt algorithm, introduced in Debian
# 11. Without this option, the default is Unix crypt. Prior releases
# used the option "sha512"; if a shadow password hash will be shared
# between Debian 11 and older releases replace "yescrypt" with "sha512"
# for compatibility. The "obscure" option replaces the old
# 'OBSOLETE_CHECKS_ENAB' option in login.defs. See the pam_unix manpage
# for other options.

# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules. See
# pam-auth-update(8) for details.

# here are the per-package modules (the "Primary" block)
password      requisite          pam_pwquality.so retry=3
password      [success=2 default=ignore] pam_unix.so obscure use_authtok try_first_pass yescrypt
password      [success=1 default=ignore] pam_winbind.so try_authtok try_first_pass
# here's the fallback if no module succeeds
password      requisite          pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
password      required          pam_permit.so
# and here are more per-package modules (the "Additional" block)
password      optional          pam_gnome_keyring.so
# end of pam-auth-update config
```

Windows:





Parte 2: Configuración de Bloqueo de Cuenta tras Intentos Fallidos

- Paso 3: Implementación del Bloqueo de Cuenta

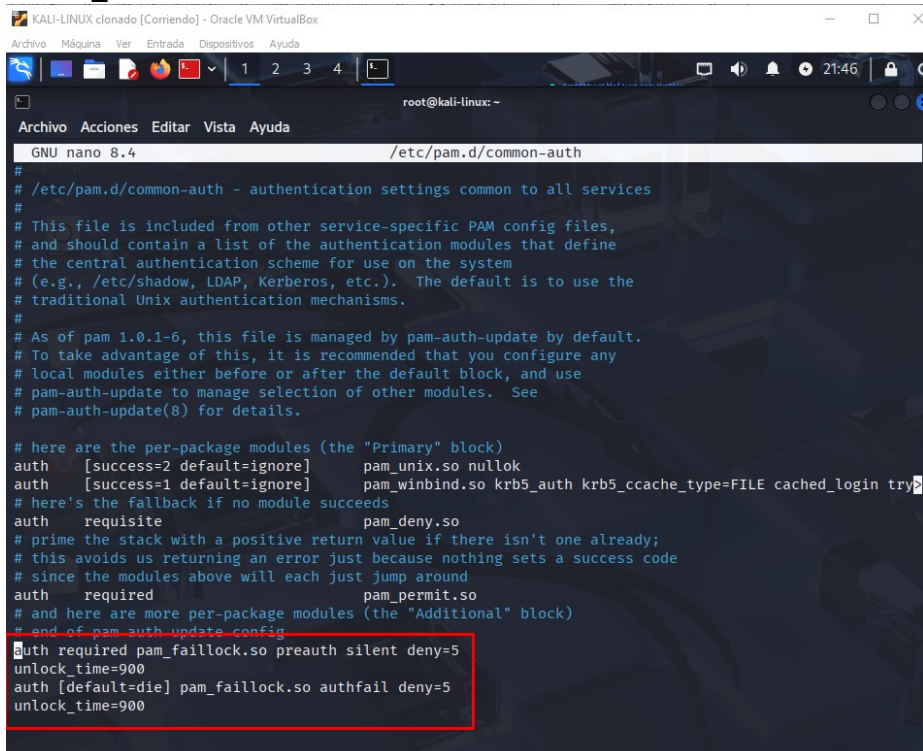
R//

Para implementar el bloqueo de cuenta en Linux, puedes usar `pam_tally2` o `pam_faillock`, dependiendo de la distribución.

Con `pam_faillock`, abre el archivo `/etc/pam.d/common-auth` y añade:

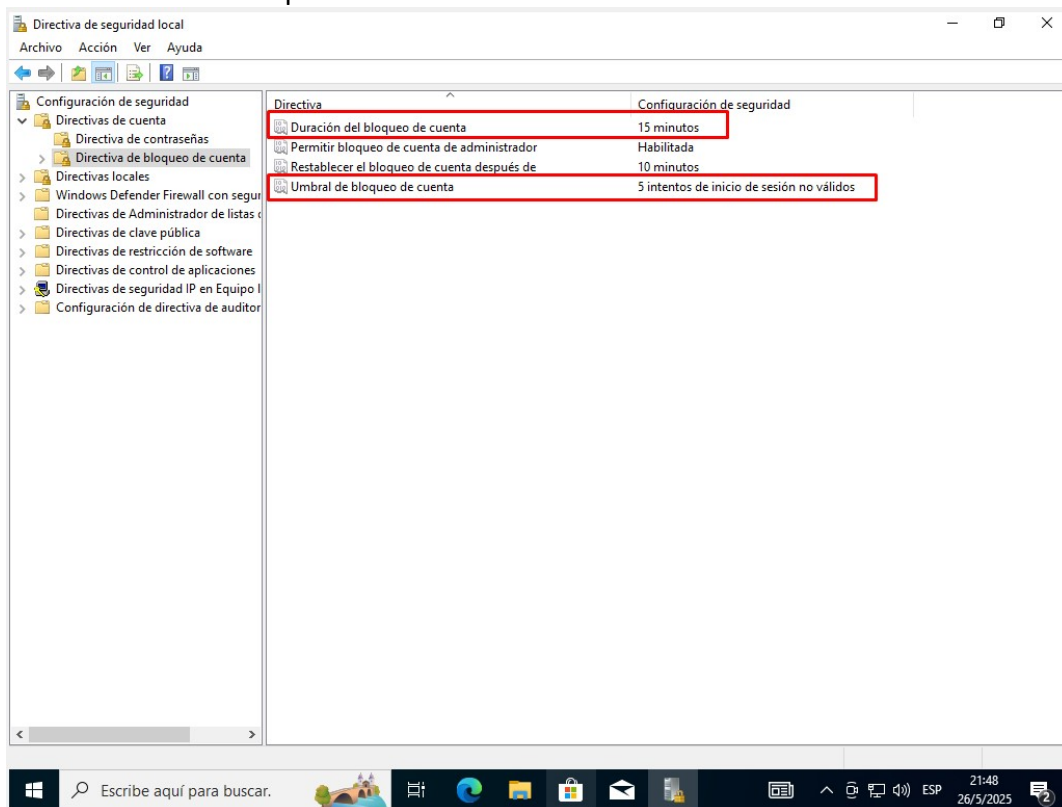
Esto bloqueará la cuenta tras 5 intentos fallidos durante 15 minutos (900 segundos).

```
auth required pam_faillock.so preauth silent deny=5
unlock_time=900
auth [default=die] pam_faillock.so authfail deny=5
unlock_time=900
```



Configura:

- Umbral de bloqueo de cuenta a 5 intentos.
- Duración del bloqueo de cuenta a 15 minutos.

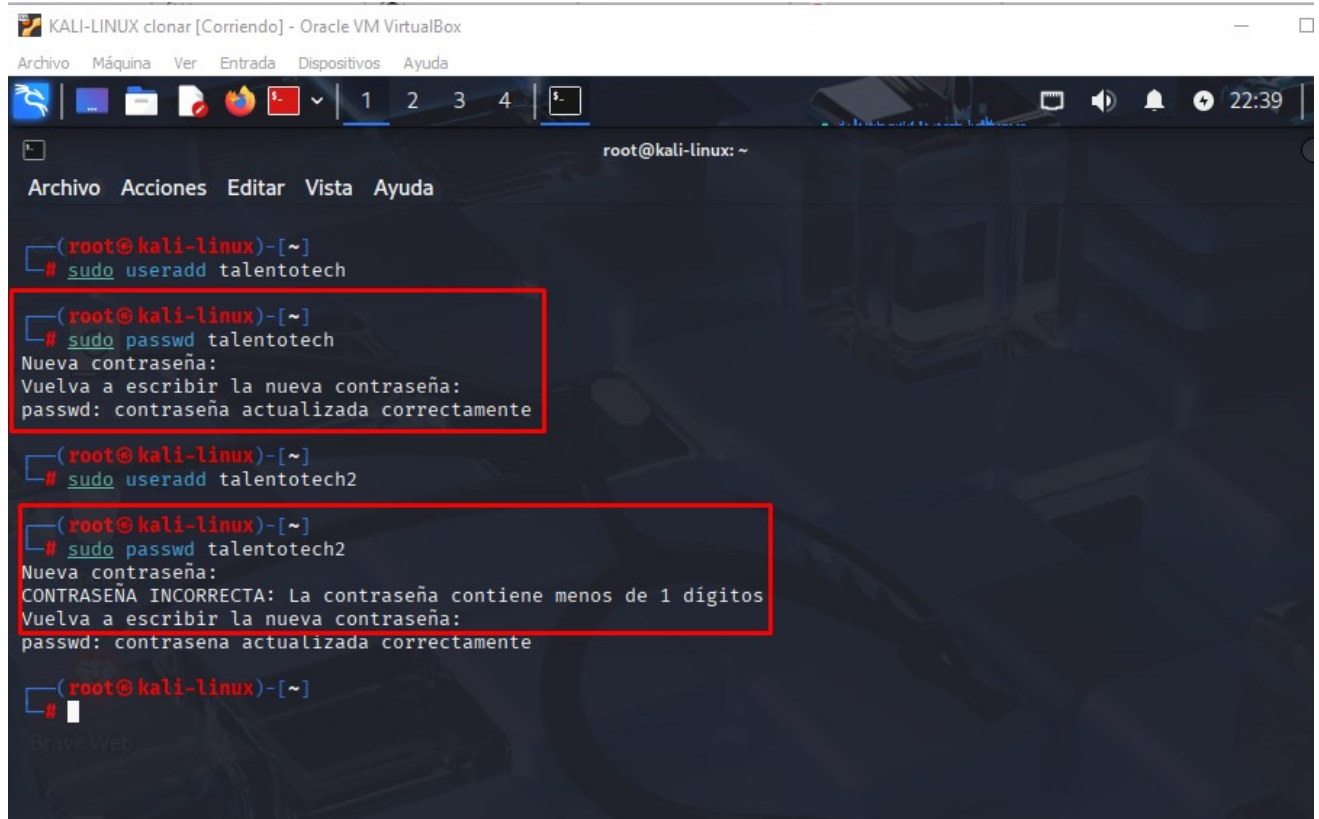


Parte 3: Verificación y Documentación de la Configuración

- Paso 4: Verificación de la Configuración de Contraseñas

R//

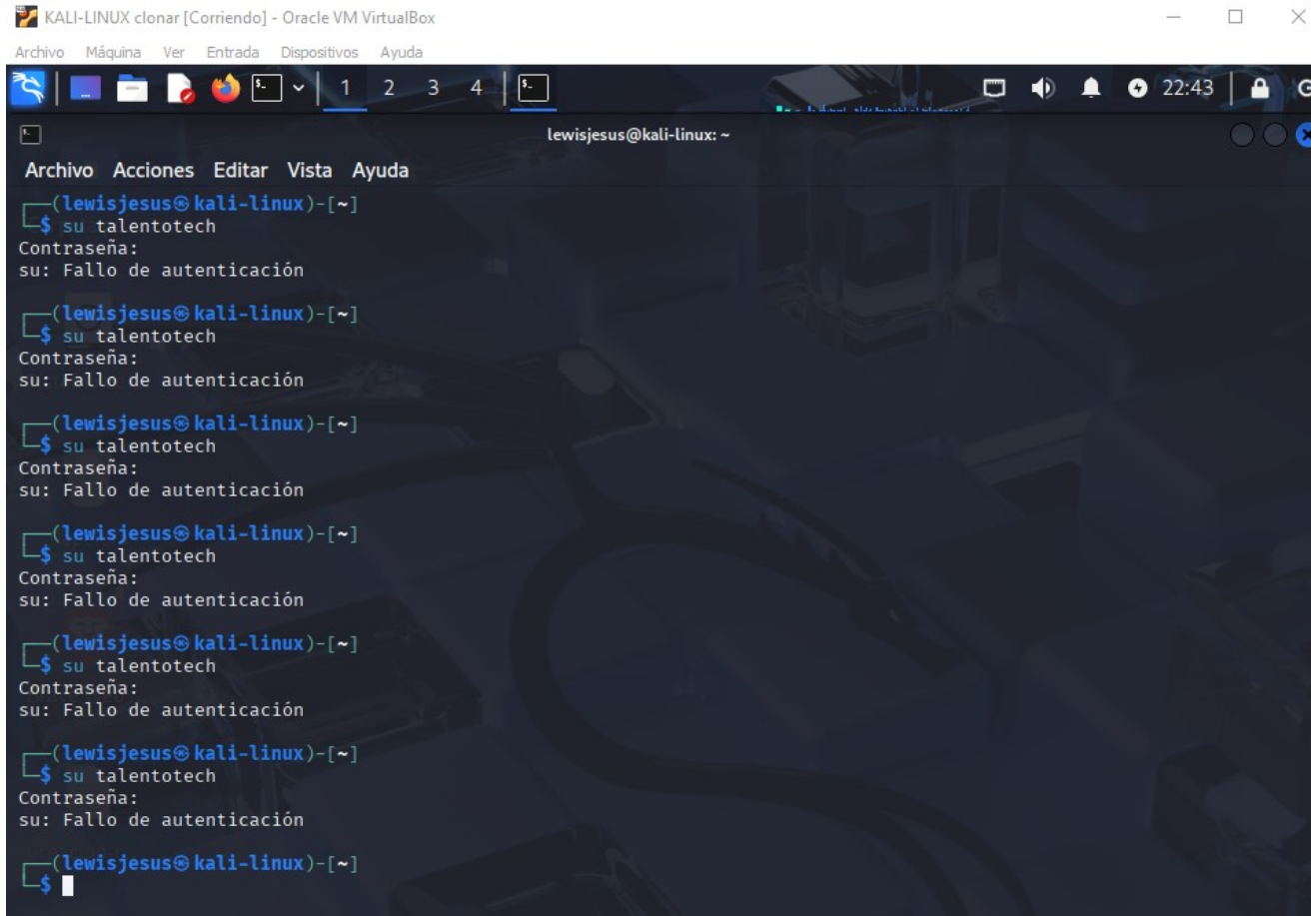
verificar la política de contraseñas probando crear o cambiar una contraseña con passwd:



- Paso 5: Verificación del Bloqueo de Cuenta

R//

Para verificar el bloqueo de cuenta en Linux, intenta iniciar sesión varias veces con una contraseña incorrecta:



The screenshot shows a terminal window titled "KALI-LINUX clonar [Corriendo] - Oracle VM VirtualBox". The user is logged in as "lewisjesus@kali-linux". The terminal shows six consecutive attempts to switch to the user "talentotech" using the "su" command. Each attempt results in the message "su: Fallo de autenticación" (su: Authentication failure). The terminal output is as follows:

```
(lewisjesus@kali-linux)-[~]
$ su talentotech
Contraseña:
su: Fallo de autenticación

(lewisjesus@kali-linux)-[~]
$ su talentotech
Contraseña:
su: Fallo de autenticación

(lewisjesus@kali-linux)-[~]
$ su talentotech
Contraseña:
su: Fallo de autenticación

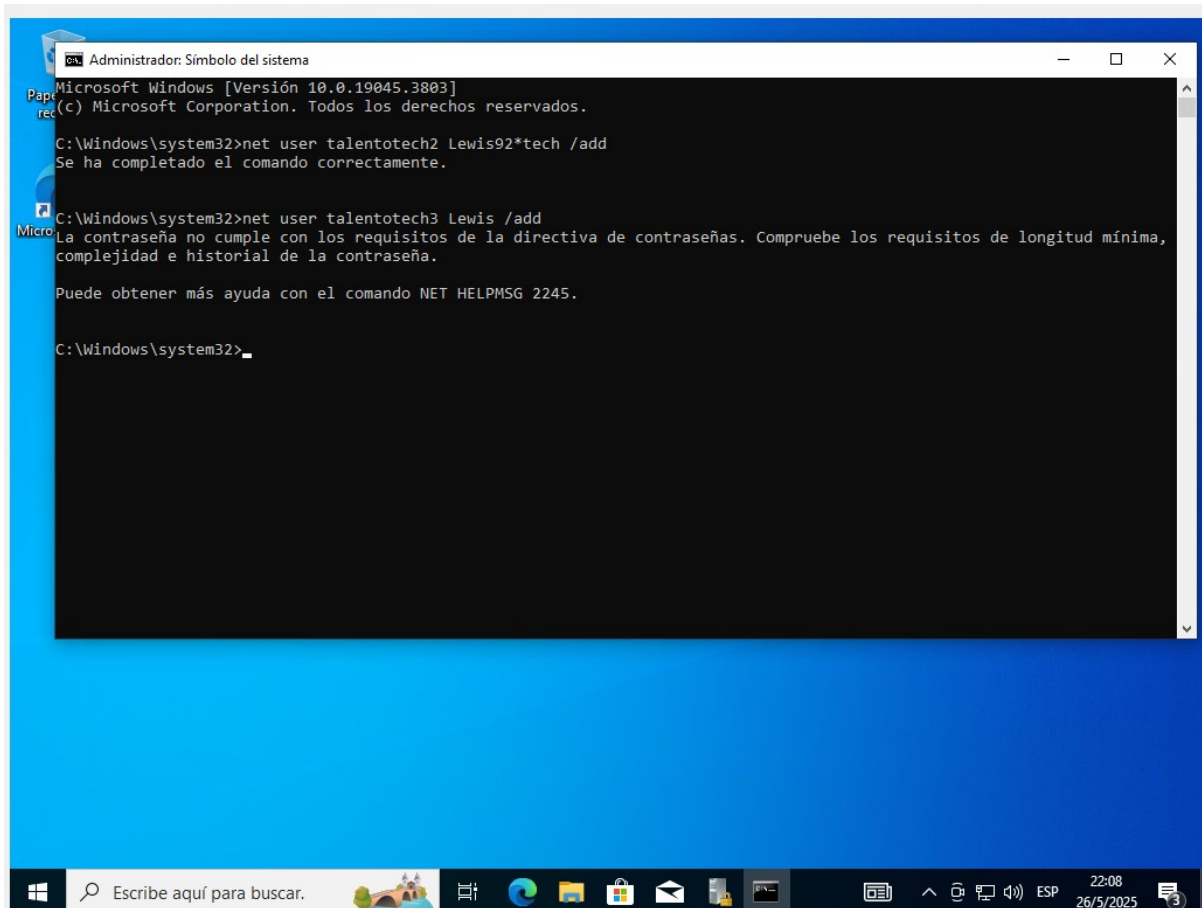
(lewisjesus@kali-linux)-[~]
$ su talentotech
Contraseña:
su: Fallo de autenticación

(lewisjesus@kali-linux)-[~]
$ su talentotech
Contraseña:
su: Fallo de autenticación

(lewisjesus@kali-linux)-[~]
$ su talentotech
Contraseña:
su: Fallo de autenticación

(lewisjesus@kali-linux)-[~]
$
```

Windows:



The screenshot shows a Windows command prompt window titled "Administrador: Símbolo del sistema". The window displays the following commands and their outputs:

```
Microsoft Windows [Versión 10.0.19045.3803]
(c) Microsoft Corporation. Todos los derechos reservados.

C:\Windows\system32>net user talentotech2 Lewis92*tech /add
Se ha completado el comando correctamente.

C:\Windows\system32>net user talentotech3 Lewis /add
La contraseña no cumple con los requisitos de la directiva de contraseñas. Compruebe los requisitos de longitud mínima,
complejidad e historial de la contraseña.

Puede obtener más ayuda con el comando NET HELPMSG 2245.

C:\Windows\system32>
```

- **Paso 6:** Documentación del Proceso

Entrega:

Los participantes deben preparar un informe que describa los pasos seguidos para configurar las políticas de contraseñas y los mecanismos de bloqueo de cuenta, incluyendo capturas de pantalla o ejemplos de comandos utilizados.